CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat 10:15. Ebatlama hattının uzak bakım hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. Üretim PLC'si, reçete dosyaları ve Safety PLC parametreleri (kapı kilit gecikmesi, mil durma süresi, vakum eşiği) değişmiş olabilir; ışık bariyeri ve robot güvenli alan ayarları henüz doğrulanmadı. Hat çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

   Önce emniyet sorumlusunu ve üretim müdürünü, ardından BT/OT güvenlik sorumlusunu ve gerekirse üretici servisini ararım. Eylemler: (1) hattı normal stopla durdurup operatörleri testere ve robot istif alanından uzaklaştırmak, (2) uzak bakım erişimini ve servis hesabını kapatmak, (3) kanıtı korumak (log, ekran görüntüsü, PLC ve reçetelerin mevcut hâli, saat notları). Resetlemem, gücü kesmem.

2. İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Işık bariyeri (test çubuğuyla kesince STO), kapı kilidi ve mil durma süresi, vakum düşme tepkisi ve alan tarayıcı testi yapılır; Safety PLC programı ve parametreleri yedekle/checksum ile karşılaştırılır. Korunan kanıt: uzak bakım ve firewall logları, 03:00 oturum kayıtları, PLC ve robot konfigürasyon kopyaları, son reçete dosyaları (hash), USB kayıtları. Kapatılan hesap: ortak servis hesabı (parola değiştirilir, uzak erişim kapalı kalır).

3. 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

   Ne oldu (ortak hesapla yetkisiz erişim şüphesi), ne zaman fark edildi (10:15), hangi ürün ve sürüm etkilendi, emniyet fonksiyonları ve reçeteler doğrulandı mı, alınan ilk önlemler ve irtibat kişisi. Net olmayan kısımlar araştırılıyor diye belirtilir.

4. 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (ortak hesap + internete açık erişim) ve etki analizini OT güvenlik ekibi yapar; hangi parametrenin ve reçetenin değiştiğini ve emniyet doğrulama sonucunu emniyet mühendisi yazar; kalıcı önlemi (VPN, MFA, jump server, reçete imzası) BT/OT sorumlusu planlar; bildirimi yönetim ve uyum sorumlusu onaylayıp gönderir.

5. 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak bakım, VPN ve firewall logları; servis hesabı kimlik doğrulama kayıtları; PLC, Safety PLC ve robot program sürümleri ile değişiklik kayıtları; reçete aktarım kayıtları (MES/CAD-CAM); yedekler; emniyet fonksiyon test tutanakları; olay zaman çizelgesi ve alınan kararlar.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.